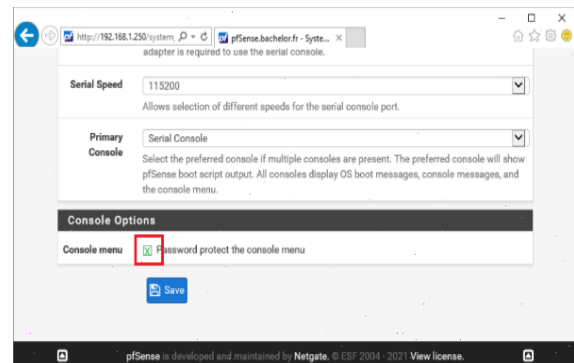
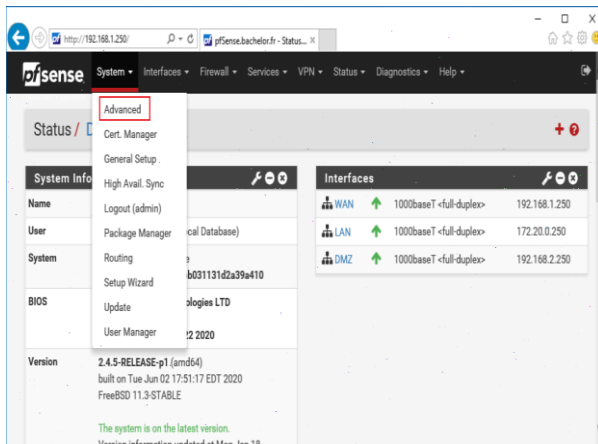




- A- Sécurisez la console par mot de passe
- B- Sécurisez l'accès par ssh
- C- Sécurisez L'interface web par https
 - a- Créer une autorité de certification interne
 - b- Générer un certificat web
 - c- Injecter le certificat web dans mon serveur pfsense

A- Sécuriser la console Pfsense

vous cochez la case console menu et vous Sauvegardez



On constate que ma console à un login

```
WAN (wan)      -> em0      -> v4: 192.168.1.250/24
LAN (lan)      -> em1      -> v4: 172.20.0.250/24
OPT1 (opt1)    -> em2      -> v4: 192.168.2.250/24

0) Logout (SSH only)
1) Assign Interfaces
2) Set interface(s) IP address
3) Reset webConfigurator password
4) Reset to factory defaults
5) Reboot system
6) Halt system
7) Ping host
8) Shell

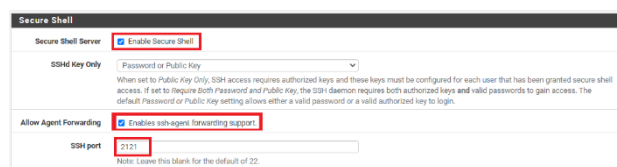
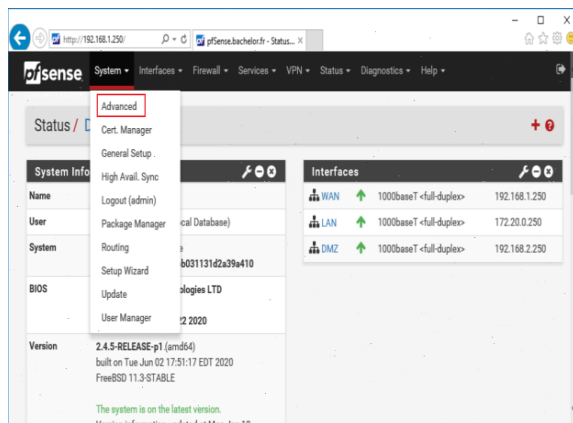
9) pfTop
10) Filter Logs
11) Restart webConfigurator
12) PHP shell + pfSense tools
13) Update from console
14) Disable Secure Shell (sshd)
15) Restore recent configuration
16) Restart PHP-FPM

Enter an option:

FreeBSD/amd64 (Heimdall.sitka.local) (ttyv0)
login: █
```

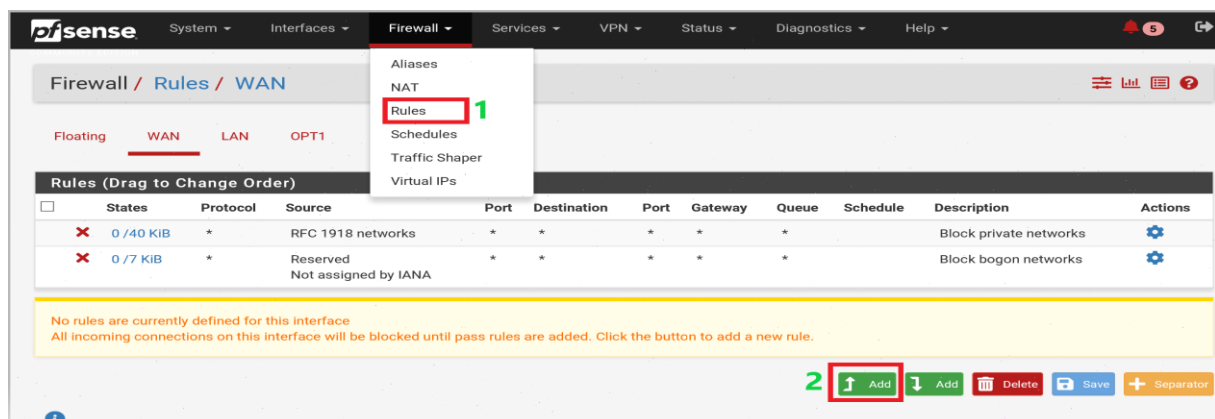
B- Sécurisez l'accès par ssh

On active ssh pour accéder à la console de manière sécurisée on change le port par défaut en (2121) en terme de sécurité il est toujours conseillé de changer les port par défaut; on peut aussi faire une authentification avec clé **privé/public** au lieu d'une authentification par mot de passe



Lan-

Maintenant il faut une **règle** autorisant **ssh** sur l'interface **Wan** on va dans le menu **interface +rule +ad**



On rentre les choix ci-dessous après il ne faut pas oublier d'enregistrer et d'appliquer les changements comme indiqué dans ces captures d'écrans.

Firewall / Rules / Edit

Edit Firewall Rule

Action Pass

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface WAN

Choose the interface from which packets must come to match this rule.

Address Family IPv4

Select the Internet Protocol version this rule applies to.

Protocol TCP

Choose which IP protocol this rule should match.

Source

Source ☐ Invert match any Source Address /

[Display Advanced](#)

The **Source Port Range** for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

Destination ☐ Invert match WAN address Destination Address /

Destination Port Range (other) 2121 (other) 2121

From Custom To Custom

Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options

Log ☒ Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description authoriser ssh

A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.

Advanced Options [Display Advanced](#)

Rule Information

Tracking ID 1640165746

Created 12/22/21 10:35:46 by admin@172.20.0.14 (Local Database)

Updated 12/22/21 10:39:53 by admin@172.20.0.14 (Local Database)

[Save](#)

Après avoir enregistré [Save](#) on applique les changements



Firewall / Rules / WAN

The firewall rule configuration has been changed.
The changes must be applied for them to take effect.

[Apply Changes](#)

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	0/0 B	*	RFC 1918 networks	*	*	*	*	*		Block private networks	Settings
☒	0/247 KiB	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogon networks	Settings
☐	0/0 B	IPv4 TCP	*	*	WAN net	22 (SSH)	*	none		Laisser passé ssh	Add Delete Save Separator

Attention sur Windows 2016 ssh n'est pas installé nativement contrairement à Windows 2019 ou Windows 10 sur ces deux dernière version ssh est parmi les fonctionnalités qu'on peut installer. Donc pour Windows 2016 suivre la procédure du fichier ssh_2016.docs pour installer ssh

On teste la connexion à l'intérieur de notre périmètre j'utilise une des machines dans un Lan :

Le serveur pfsense m'envoie l'empreinte numérique de sa clé publique :

```
*** Welcome to pfSense 2.5.2-RELEASE (amd64) on heimdall ***
```

Enter an option:

En fin je compare les deux empreintes on constate qu'elles sont identiques



```
PS C:\> ssh admin@192.168.1.250
ssh: connect to host 192.168.1.250 port 22: Connection timed out
PS C:\> |
```

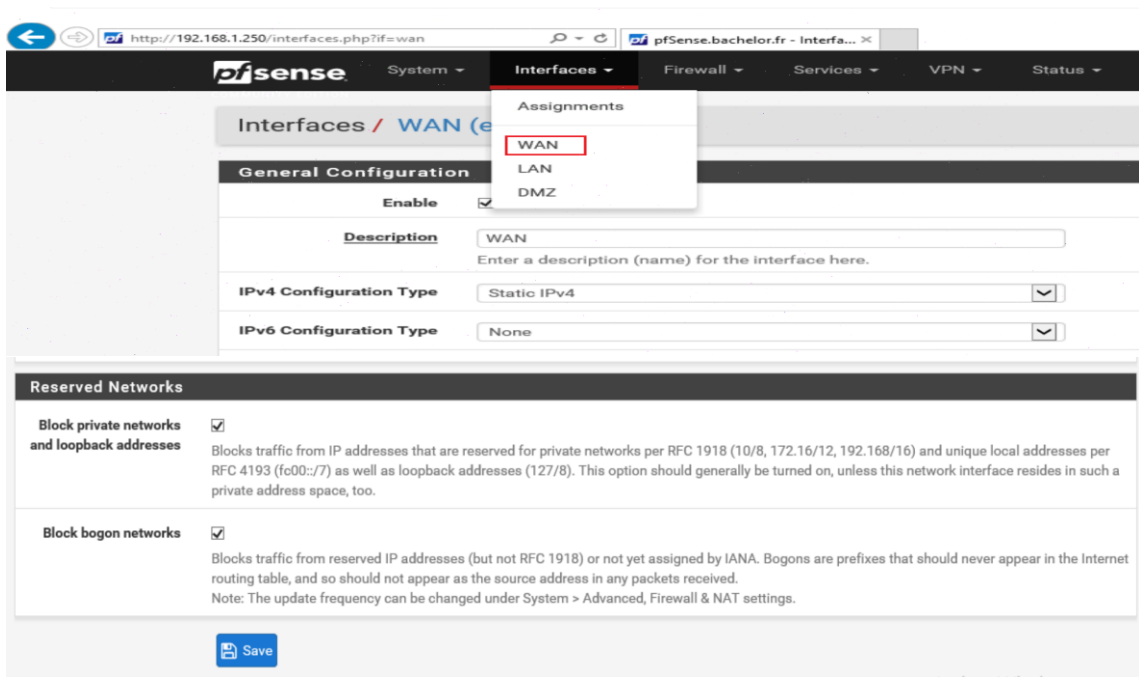
On remarque qu'il y'a **échec de connexion** ; on essaye de faire un **ping** sur cette interface, même constat

```
Windows PowerShell
PS C:\> ping 192.168.1.250

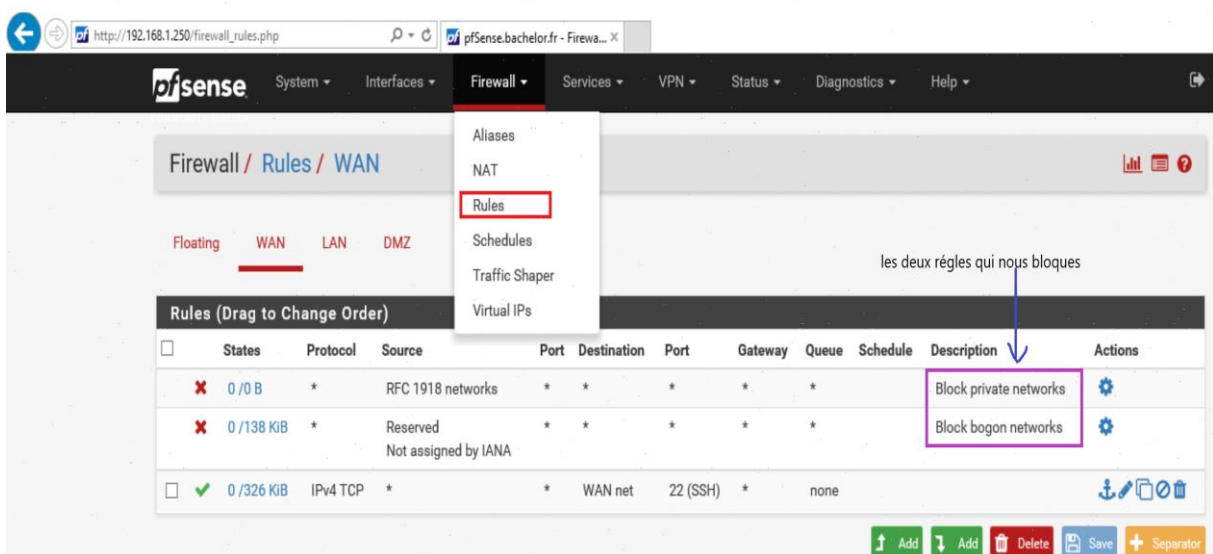
Envoi d'une requête 'Ping' 192.168.1.250 avec 32 octets de données :
Réponse de 192.168.1.156 : Impossible de joindre l'hôte de destination.
Réponse de 192.168.1.156 : Impossible de joindre l'hôte de destination.
Réponse de 192.168.1.156 : Impossible de joindre l'hôte de destination.
Réponse de 192.168.1.156 : Impossible de joindre l'hôte de destination.

Statistiques Ping pour 192.168.1.250:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
PS C:\>
```

Cet échec est normal car PfSense bloque toutes requêtes venant d'une adresse privée en dehors de son périmètre **Wan**, **sitka_lan** et **opt_lan**, on peut vérifier ceci aisément en allant dans le menu **Interface + Wan** tout en bas de la page on trouve deux cases cochées ce qui explique ce blocage



On trouve la même chose dans les règles par défaut de l'interface wan



Maintenant on va essayer d'accéder à notre serveur PfSense à partir de l'extérieur en utilisant notre adresse publique.

Tout d'abord :

- 1- Il faut accéder à la box internet et ouvrir le port 22 en créant une redirection de port

Service	Adresse IP du serveur	Protocole	Ports externes	Ports internes	Activer la règle
Utilisateur					
SSH	192.168.1.250	TCP/UDP	22 • 22	22 • 22	on

- 2- Ensuite il faut déterminer notre adresse publique soit à partir de la box ou un site internet <http://www.whatismyip.com>

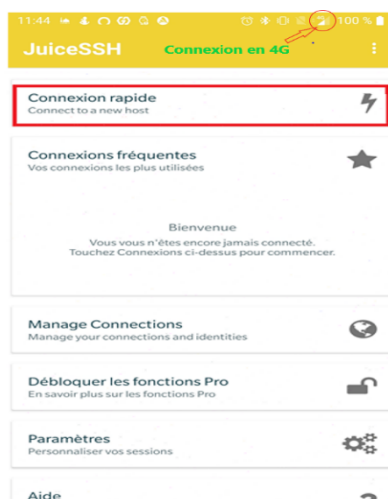
- 3- Après sur notre smartphone on télécharge un client ssh sur  google store
Juicessh



JuiceSSH - SSH Client

- 4- Sur notre smartphone il faut qu'on se mette en 4G et non en wifi car il na faut pas oublier que PfSense bloque les connexions provenant d'adresse IP en dehors de son périmètre.
- 5- On ouvre l'application et on commence à établir notre connexion ssh

On sélectionne connexion rapide

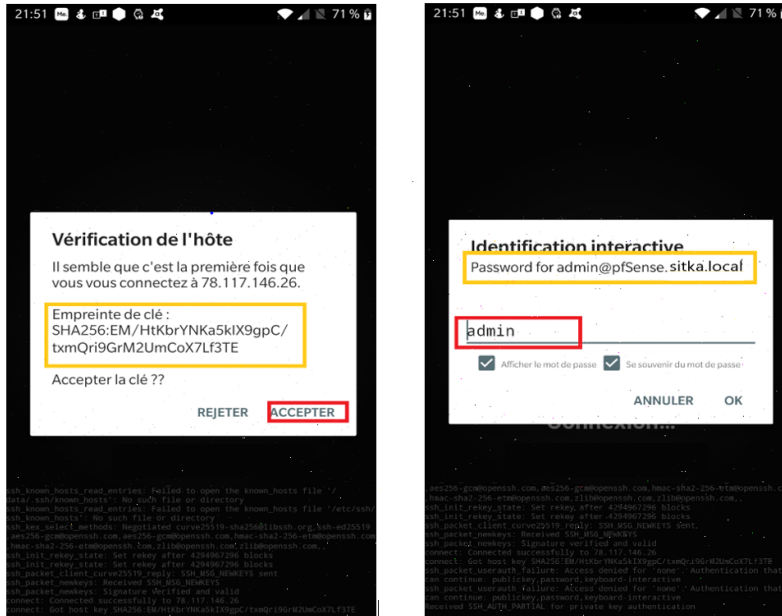


ssh admin@ adresse publique

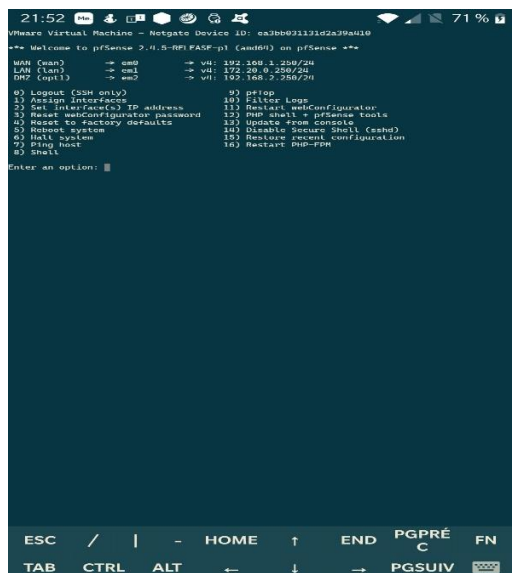


Le serveur nous envoie l'empreinte de sa clé publique
On constate que c'est la même que celle qu'on a calculé
Sur le serveur

EM/HtKbrYNKa5kIX9gpC/txmQri9GrM2UmCoX7Lf3TE rentre le mot de passe admin



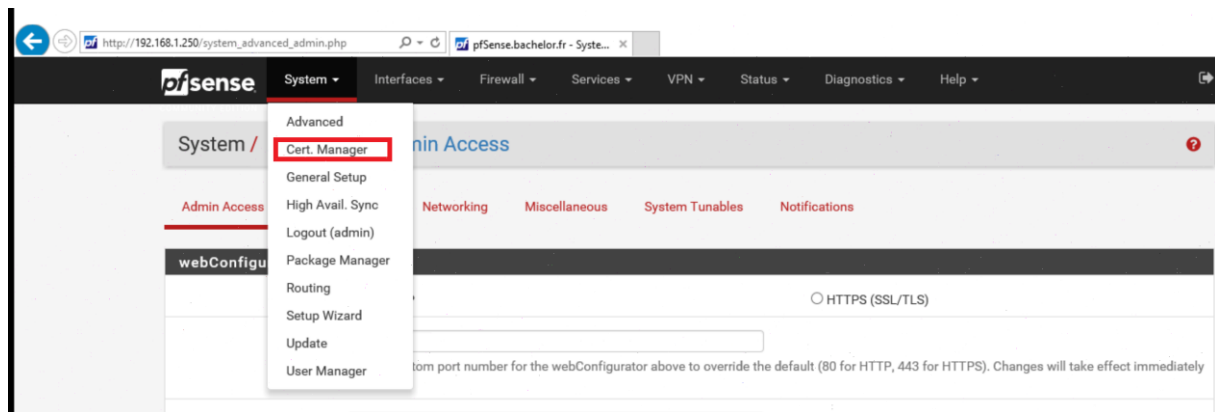
Après on tombe sur notre console PfSense



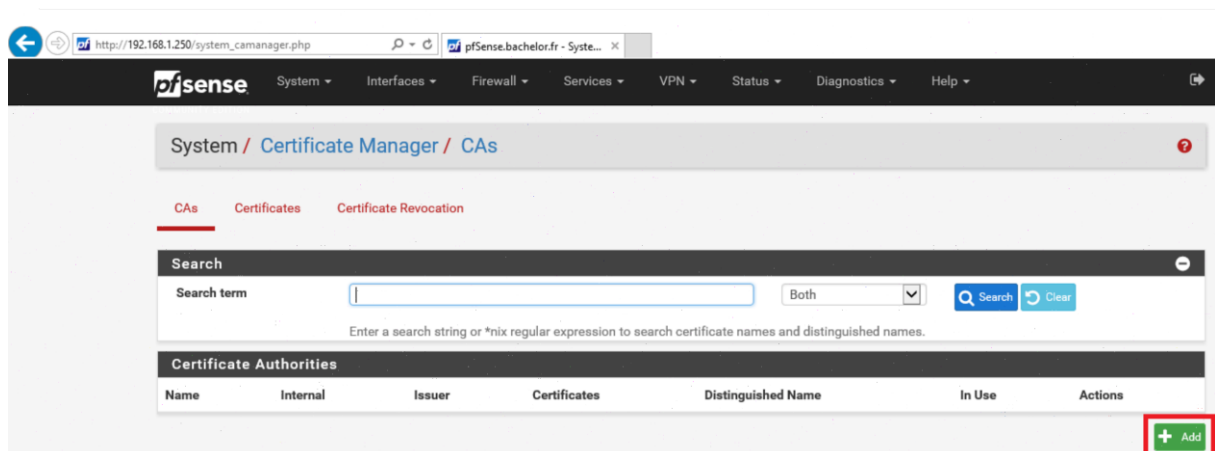
D- Sécurisez L'interface web par https

1- Créer une autorité de certification interne

On va dans le menu **système + CertManager**



On commence à créer une autorité de certification interne



On remplit les champs suivants

pfSense COMMUNITY EDITION System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

System / Certificate Manager / CAs / Edit

CA's Certificates Certificate Revocation

Create / Edit CA

Descriptive name	Autorité de certification Sitka
Method	Create an internal Certificate Authority ▾
Trust Store	☒ Add this Certificate Authority to the Operating System Trust Store When enabled, the contents of the CA will be added to the trust store so that they will be trusted by the operating system.
Randomize Serial	☒ Use random serial numbers when signing certifies When enabled, if this CA is capable of signing certificates then serial numbers for certificates signed by this CA will be automatically randomized and checked for uniqueness instead of using the sequential value from Next Certificate Serial.

Internal Certificate Authority

Key type	RSA ▾
	2048 ▾ The length to use when generating a new RSA key, in bits. The Key Length should not be lower than 2048 or some platforms may consider the certificate invalid.
Digest Algorithm	sha256 ▾
	The digest method used when the CA is signed. The best practice is to use an algorithm stronger than SHA1. Some platforms may consider weaker digest algorithms invalid
Lifetime (days)	3650
Common Name	internal-ca-sitka
	The following certificate authority subject components are optional and may be left blank.
Country Code	FR ▾
State or Province	IDF
City	Paris
Organization	sitka
Organizational Unit	SK

 Save

Une fois qu'on enregistre nos paramètre notre autorité de certification apparait, on appuie sur le crayon pour éditer notre CA

pfSense COMMUNITY EDITION

System / Certificate Manager / CAs

Search

Search term: Both

Enter a search string or *nix regular expression to search certificate names and distinguished names.

Name	Internal	Issuer	Certificates	Distinguished Name	In Use	Actions
Autorité de certification Sitka	✓	self-signed	0	ST=IDF, OU=SK, O=sitka, L=Paris, CN=internal-ca-sitka, C=FR Valid From: Sat, 27 Nov 2021 21:31:04 +0100 Valid Until: Tue, 25 Nov 2031 21:31:04 +0100		  

On affiche notre certificat et la clé publique qui lui est associé

pfSense COMMUNITY EDITION

System / Certificate Manager / CAs / Edit

Create / Edit CA

Descriptive name

Method

Trust Store ☒ Add this Certificate Authority to the Operating System Trust Store
When enabled, the contents of the CA will be added to the trust store so that they will be trusted by the operating system.

Randomize Serial ☒ Use random serial numbers when signing certificates
When enabled, if this CA is capable of signing certificates then serial numbers for certificates signed by this CA will be automatically randomized and checked for uniqueness instead of using the sequential value from Next Certificate Serial.

Existing Certificate Authority

Certificate data

```
-----BEGIN CERTIFICATE-----
MIIEIDCCAwIgaWIBAgIIPmg7cGMSa8swDQYJKoZIhvcNAQELBQAwZD
EaMBGGA1UE
AxIMRabI50ZXJ1YWltY2EtZ210a2ExCzAJBgNVBAYTAkZSMQwvCgYDVQ
QIEwNjREYx
Paste a certificate in X.509 PEM format here.
```

Certificate Private Key (optional)

```
-----BEGIN PRIVATE KEY-----
MIIEvQIBADANBgkqhkiG9w0BAQEFAASCBCwggSjAgEAAoIBAQC70e
kVlxgQcd/7
FiH4jAa0qAi145sMX5P9Ts6INa7J2Qd88szCh2CU8vggG9V9VX2T8r
h1ebXA+BvH
Paste the private key for the above certificate here. This is optional in most cases, but is required when generating a Certificate Revocation List (CRL).
```

Next Certificate Serial
Enter a decimal number to be used as a sequential serial number for the next certificate to be signed by this CA.

2- Générer un certificat web

Maintenant on va créer notre certificat web délivrer par la CA **autorité de certification sitka** qu'on a mis en place dans l'étape précédente il suffit de cliquer sur add et remplir les champs nécessaires

System / Certificate Manager / Certificates

CA's **Certificates** Certificate Revocation

Search

Search term Both

Enter a search string or *nix regular expression to search certificate names and distinguished names.

Name	Issuer	Distinguished Name	In Use	Actions
webConfigurator default (6001f6f281597) Server Certificate CA: No Server: Yes	self-signed	O=pfSense webConfigurator Self-Signed Certificate, CN=pfSense-6001f6f281597 Valid From: Fri, 15 Jan 2021 21:11:30 +0100 Valid Until: Thu, 17 Feb 2022 21:11:30 +0100		

+ Add/Sign

ci-dessous les champs remplie pour créer notre certificat

Add/Sign a New Certificate

MethodCreate an internal Certificate

Descriptive nameCertificat SSL pour le serveur web Heimdall

Internal Certificate

Certificate authorityAutorité de certification Sitka

Key typeRSA

2048

The length to use when generating a new RSA key, in bits.
The Key Length should not be lower than 2048 or some platforms may consider the certificate invalid.

Digest Algorithmsha256

The digest method used when the certificate is signed.
The best practice is to use an algorithm stronger than SHA1. Some platforms may consider weaker digest algorithms invalid

Lifetime (days)3650

The length of time the signed certificate will be valid, in days.
Server certificates should not have a lifetime over 398 days or some platforms may consider the certificate invalid.

Common Nameheimdall.sitka.local

The following certificate subject components are optional and may be left blank.

Country CodeFR

State or ProvinceIDF

CityParis

Organizationsitka

Organizational UnitSK

Certificate Attributes

Attribute Notes The following attributes are added to certificates and requests when they are created or signed. These attributes behave differently depending on the selected mode.

For Internal Certificates, these attributes are added directly to the certificate as shown.

Certificate Type Server Certificate

Add type-specific usage attributes to the signed certificate. Used for placing usage restrictions on, or granting abilities to, the signed certificate.

Alternative Names

Type	Value	Action
FQDN or Hostname	heimdall.sitka.local	Delete
FQDN or Hostname	pfsense.sitka.local	Delete
IP address	172.20.0.250	Delete
IP address	192.168.1.250	Delete
IP address	192.168.2.250	Delete
URI	www.heimdall.local	Delete

Enter additional identifiers for the certificate in this list. The Common Name field is automatically added to the certificate as an Alternative Name. The signing CA may ignore or change these values.

Add + Add

Save

Une fois qu'on enregistre notre certificat apparait

pfSense COMMUNITY EDITION System Interfaces Firewall Services VPN Status Diagnostics Help

System / Certificate Manager / Certificates

Created internal certificate Certificat SSL pour le serveur web Heimdall

CA's Certificates Certificate Revocation

Search

Search term Both Search Clear

Enter a search string or *nix regular expression to search certificate names and distinguished names.

Certificates

Name	Issuer	Distinguished Name	In Use	Actions
webConfigurator default (61a2591ac0fff) Server Certificate CA: No Server: Yes	self-signed	O=pfSense webConfigurator Self-Signed Certificate, CN=pfSense-61a2591ac0fff Valid From: Sat, 27 Nov 2021 17:13:14 +0100 Valid Until: Fri, 30 Dec 2022 17:13:14 +0100		    
Certificat SSL pour le serveur web Heimdall Server Certificate CA: No Server: Yes	Autorité de certification Sitka	ST=IDF, OU=SK, O=sitka, L=Paris, CN=heimdall.sitka.local, C=FR Valid From: Sat, 27 Nov 2021 22:21:01 +0100 Valid Until: Tue, 25 Nov 2031 22:21:01 +0100		    

+ Add/Sign

3- Injecter le certificat web dans mon serveur PfSense

Maintenant on va injecter notre certificat dans notre serveur web PfSense, donc on va dans **système + Avanced**

- On sélectionne notre certificat crée
- On laisse le port par défaut
- On laisse 2 en nombre de connexion simultanée c'est-à-dire 2 personnes max peuvent se connecter sur l'interface web PfSense
- On refuse la connexion en http
- On refuse que le navigateur enregistre les données de connexion

Admin Access Firewall & NAT Networking Miscellaneous System Tunables Notifications

webConfigurator

Protocol ☐ HTTP ☒ **HTTPS (SSL/TLS)**

SSL/TLS Certificate **Certificat SSL pour le serveur web Heimdall**
Certificates known to be incompatible with use for HTTPS are not included in this list.

TCP port
Enter a custom port number for the webConfigurator above to override the default (80 for HTTP, 443 for HTTPS). Changes will take effect immediately after save.

Max Processes
Enter the number of webConfigurator processes to run. This defaults to 2. Increasing this will allow more users/browsers to access the GUI concurrently.

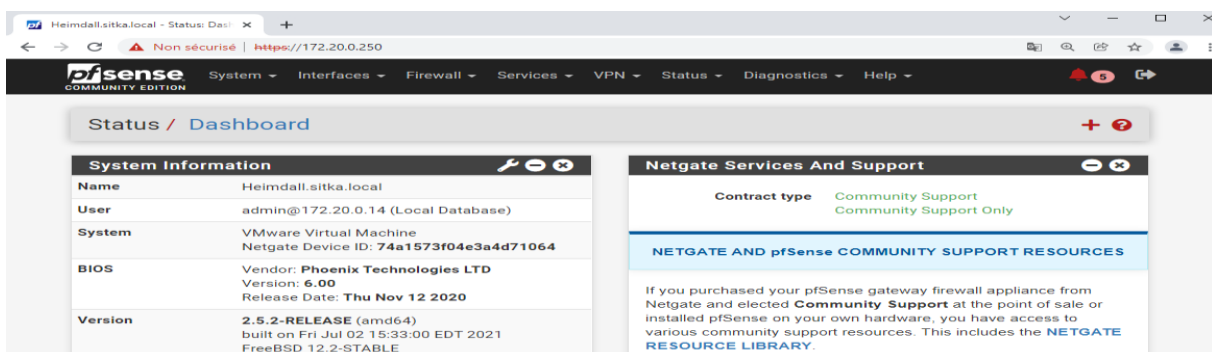
WebGUI redirect ☒ **Disable webConfigurator redirect rule**
When this is unchecked, access to the webConfigurator is always permitted even on port 80, regardless of the listening port configured. Check this box to disable this automatically added redirect rule.

HSTS ☐ Disable HTTP Strict Transport Security
When this is unchecked, Strict-Transport-Security HTTPS response header is sent by the webConfigurator to the browser. This will force the browser to use only HTTPS for future requests to the firewall FQDN. Check this box to disable HSTS. (NOTE: Browser-specific steps are required for disabling to take effect when the browser already visited the FQDN while HSTS was enabled.)

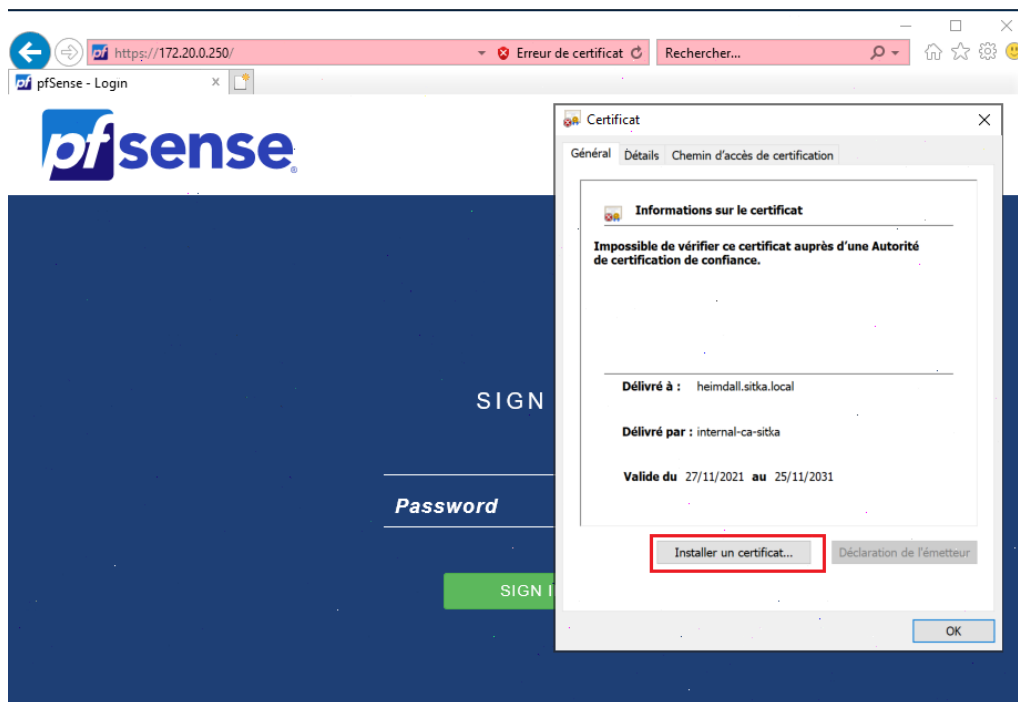
OCSP Must-Staple ☐ Force OCSP Stapling in nginx
When this is checked, OCSP Stapling is forced on in nginx. Remember to upload your certificate as a full chain, not just the certificate, or this option will be ignored by nginx.

WebGUI Login Autocomplete ☒ **Enable webConfigurator login autocomplete**
When this is checked, login credentials for the webConfigurator may be saved by the browser. While convenient, some security standards require this to be disabled. Check this box to enable autocomplete on the login form so that browsers will prompt to save credentials (NOTE: Some browsers do not respect this option).

Après on sauvegarde notre navigateur va démarrer automatiquement
On se connecte sur l'interface <https://172.20.0.250>



Le certificat représente des erreurs car notre autorité de certification n'est pas de confiance donc il faut l'intégrer dans le magasin des autorités de certification de confiance en installant le certificat de l'autorité racine



Protection de la connexion

A screenshot of the "Login Protection" configuration page in pfSense. The page has a dark header with the title "Login Protection". Below the header, there are several configuration fields, each with a red rectangle highlighting the input value. The fields are: "Threshold" with a value of 8, "Blocktime" with a value of 180, and "Detection time" with a value of 259200. Below these fields, there is a "Whitelist" section with a text input field containing "Address" and a dropdown menu showing "128". At the bottom, there is an "Add address" button with a green plus icon. The page also includes explanatory text for each field and a note about the whitelist: "Addresses added to the whitelist will bypass login protection."